

Test Specifications: Auth Domain

Gema Event Management Platform
Generated: 2026-02-25

Source files: routes/auth.routes.ts, validators: auth.validator.ts, user.validator.ts
Middleware: authLimiter, passwordResetLimiter, emailVerificationLimiter, authenticate, authenticateOptional

Registration

Test ID	Description	Preconditions	Input	Expected Output	Priority
TC-AUTH-001	Happy path: register new user	Email not in use	Valid { email, password, firstName, lastName }	HTTP 201; JWT access token in cookie; user created in DB	High
TC-AUTH-002	Duplicate email registration	User with same email already exists	Same email as existing user	HTTP 409 or 400; error message indicating email in use	High
TC-AUTH-003	Missing required field — email	N/A	Body without email field	HTTP 422; validation error listing email as required	High
TC-AUTH-004	Invalid email format	N/A	email = "notanemail"	HTTP 422; validation error	High
TC-AUTH-005	Weak password	N/A	password = "123" (below minimum length)	HTTP 422; validation error	High
TC-AUTH-006	Rate limiter blocks repeated registration attempts	N/A	11+ POST /auth/register requests from same IP within window	HTTP 429 after threshold reached	High
TC-AUTH-007	Admin registration requires secret key	No prior auth	Valid admin payload without correct adminSecret	HTTP 403 or 401	High
TC-AUTH-008	Admin registration with correct secret key	N/A	Valid admin payload with correct adminSecret	HTTP 201; user created with role = admin	High
TC-AUTH-009	XSS payload in firstName field	N/A	firstName = "<script>alert(1)</script>"	Input sanitized or rejected; no script stored/reflected	High
TC-AUTH-010	NoSQL injection in email field	N/A	email = { "\$gt": "" }	HTTP 422 or sanitized; no unauthorized data returned	High

Login

Test ID	Description	Preconditions	Input	Expected Output	Priority
TC-AUTH-011	Happy path: login with correct credentials	User exists, email verified	{ email, password }	HTTP 200; access token in httpOnly cookie; refresh token issued	High
TC-AUTH-012	Wrong password	User exists	Correct email, wrong password	HTTP 401; generic "invalid credentials" message	High
TC-AUTH-013	Non-existent email	No user with email	{ email: "ghost@example.com", password: "..." }	HTTP 401; same generic error (no user enumeration)	High
TC-AUTH-014	Unverified email login	User created but email not verified	Valid credentials, unverified account	HTTP 403; error indicating email must be verified	High
TC-AUTH-015	Rate limiter blocks repeated login failures	N/A	11+ failed login attempts from same IP	HTTP 429 after threshold	High
TC-	Login with Firebase	...	... POST /auth/firebase with valid	HTTP 200; JWT issued; user created ...	

AUTH-016	auth returns token	Firebase token valid	Firebase ID token	if first login	High
TC-AUTH-017	Firebase auth with invalid/expired token	N/A	Invalid Firebase ID token	HTTP 401	High
TC-AUTH-018	Firebase auth missing token field	N/A	Body without idToken field	HTTP 422; validation error	Medium

Token Management

Test ID	Description	Preconditions	Input	Expected Output	Priority
TC-AUTH-019	Happy path: refresh access token	Valid refresh token in cookie/body	POST /auth/refresh-token with valid refresh token	HTTP 200; new access token issued	High
TC-AUTH-020	Expired refresh token	Refresh token past TTL	Expired refreshToken	HTTP 401; token expired error	High
TC-AUTH-021	Invalid/tampered refresh token	N/A	Malformed JWT string	HTTP 401	High
TC-AUTH-022	Missing refresh token	N/A	POST /auth/refresh-token with no token	HTTP 422; validation error	High
TC-AUTH-023	Logout clears cookies	User is logged in	POST /auth/logout	HTTP 200; Set-Cookie headers clear access/refresh tokens	High
TC-AUTH-024	Logout without active session (already logged out)	No token present	POST /auth/logout	HTTP 200; idempotent, no error	Medium
TC-AUTH-025	JWT clock skew tolerance — token issued 55 seconds in future	Auth middleware configured with 60s tolerance	Access token with iat slightly in future	Request authenticated successfully	Medium

Profile & Password Management

Test ID	Description	Preconditions	Input	Expected Output	Priority
TC-AUTH-026	Happy path: GET /auth/me with valid token	User authenticated	Valid access token in cookie	HTTP 200; user object (no password/sensitive fields)	High
TC-AUTH-027	GET /auth/me without token (optional auth)	No cookie set	No Authorization header	HTTP 200; empty/null user data or guest response	Medium
TC-AUTH-028	GET /auth/profile requires auth	No token	GET /auth/profile without Authorization	HTTP 401	High
TC-AUTH-029	Happy path: update profile	User authenticated	PUT /auth/profile with valid { firstName, lastName }	HTTP 200; user fields updated in DB	High
TC-AUTH-030	Profile update with oversized payload	User authenticated	firstName = 500-char string (exceeds limit)	HTTP 422; validation error	Medium
TC-AUTH-031	Happy path: change password	User authenticated, knows current password	{ currentPassword, newPassword }	HTTP 200; password updated; existing sessions invalidated	High
TC-AUTH-032	Change password — wrong current password	User authenticated	Incorrect currentPassword	HTTP 401 or 400	High
TC-AUTH-033	Change password without authentication	No token	PUT /auth/change-password	HTTP 401	High
TC-AUTH-034	Forgot password — valid email	User exists	{ email: "user@example.com" }	HTTP 200; reset OTP/link sent via email; same response whether email exists or not	High

TC-AUTH-035	Forgot password — non-existent email	No user with email	{ email: "nobody@example.com" }	HTTP 200; same response (no user enumeration)	High
TC-AUTH-036	Forgot password rate limiter	N/A	6+ POST /auth/forgot-password from same IP	HTTP 429 after threshold	High
TC-AUTH-037	Reset password — valid token and new password	Valid reset token	{ token, newPassword }	HTTP 200; password updated	High
TC-AUTH-038	Reset password — expired token	Token TTL exceeded	Expired token	HTTP 400 or 401; token expired error	High
TC-AUTH-039	Reset password — already-used token	Token previously consumed	Same token reused	HTTP 400; token already used	High

Email Verification

Test ID	Description	Preconditions	Input	Expected Output	Priority
TC-AUTH-040	Happy path: verify email with correct OTP	OTP sent to user email	{ email, otp } with matching OTP	HTTP 200; emailVerified: true on user	High
TC-AUTH-041	Verify email — wrong OTP	N/A	Incorrect OTP value	HTTP 400; invalid OTP error	High
TC-AUTH-042	Verify email — expired OTP	OTP past TTL	Expired OTP	HTTP 400; OTP expired error	High
TC-AUTH-043	Resend verification email — valid request	User not yet verified	{ email }	HTTP 200; new OTP sent; previous OTP invalidated	High
TC-AUTH-044	Resend verification — already verified user	User already verified	{ email } of verified user	HTTP 400 or 200 with informational message	Medium
TC-AUTH-045	Email verification rate limiter	N/A	6+ requests from same IP within window	HTTP 429	High

Address Management

Test ID	Description	Preconditions	Input	Expected Output	Priority
TC-AUTH-046	Happy path: add new address	User authenticated	POST /auth/addresses with valid address fields	HTTP 201; address added to user's addresses array	High
TC-AUTH-047	Add address — unauthenticated	No token	POST /auth/addresses	HTTP 401	High
TC-AUTH-048	Add address — missing required fields	User authenticated	Incomplete address payload	HTTP 422; validation errors for missing fields	Medium
TC-AUTH-049	Update address at valid index	User has >=1 address	PUT /auth/addresses/0 with new data	HTTP 200; address at index 0 updated	High
TC-AUTH-050	Update address — out-of-bounds index	User has 1 address	PUT /auth/addresses/5	HTTP 400 or 404; invalid index error	Medium
TC-AUTH-051	Update address — non-integer index	N/A	PUT /auth/addresses/abc	HTTP 422; validation error (index must be integer)	Medium
TC-AUTH-052	Delete address at valid index	User has >=1 address	DELETE /auth/addresses/0	HTTP 200; address removed	High
TC-	Delete address —	No token	DELETE /auth/addresses/0	HTTP 401	High

AUTH-053	unauthenticated	No token	DELETE /auth/addresses/0	HTTP 200	High
----------	-----------------	----------	--------------------------	----------	------

Avatar Management

Test ID	Description	Preconditions	Input	Expected Output	Priority
TC-AUTH-054	Happy path: upload avatar	User authenticated	POST /auth/upload-avatar with valid image file	HTTP 200; Cloudinary URL stored on user	High
TC-AUTH-055	Upload avatar — invalid file type	User authenticated	Non-image file (e.g., .txt, .pdf)	HTTP 422; validation error	High
TC-AUTH-056	Upload avatar — unauthenticated	No token	POST /auth/upload-avatar	HTTP 401	High
TC-AUTH-057	Delete avatar	User authenticated, avatar exists	DELETE /auth/avatar	HTTP 200; avatar removed from user and Cloudinary	High
TC-AUTH-058	Backward-compat PUT /auth/avatar	User authenticated	PUT /auth/avatar with valid image data	HTTP 200; same behavior as POST /upload-avatar	Low

Phone Verification

Test ID	Description	Preconditions	Input	Expected Output	Priority
TC-AUTH-059	Happy path: send phone OTP	User authenticated	POST /auth/send-phone-verification with valid { phone }	HTTP 200; OTP sent via SMS	High
TC-AUTH-060	Send phone OTP — invalid phone format	User authenticated	{ phone: "not-a-phone" }	HTTP 422; validation error	High
TC-AUTH-061	Verify phone — correct OTP	OTP sent	{ otp } with matching OTP	HTTP 200; phoneVerified: true on user	High
TC-AUTH-062	Verify phone — wrong OTP	N/A	Incorrect OTP	HTTP 400	High
TC-AUTH-063	Resend phone OTP	User authenticated	POST /auth/resend-phone-verification	HTTP 200; new OTP sent; previous invalidated	Medium
TC-AUTH-064	Phone verification routes require authentication	No token	Any /auth/send-phone-verification, /verify-phone, /resend-phone-verification	HTTP 401	High
TC-AUTH-065	Phone OTP rate limiter	User authenticated	6+ requests to /send-phone-verification within window	HTTP 429	High

Security Tests

Test ID	Description	Preconditions	Input	Expected Output	Priority
TC-AUTH-066	JWT from different secret rejected	N/A	Access token signed with wrong secret	HTTP 401; signature verification failure	Critical
TC-AUTH-067	JWT with alg: none attack	N/A	Token with "alg": "none" in header	HTTP 401; algorithm rejected	Critical
TC-AUTH-068	Expired access token rejected	Token past exp	Expired JWT in Authorization header	HTTP 401; token expired	Critical
TC-AUTH-069	Token replay after logout	User logs out	Reuse access token after logout	HTTP 401 (if token blacklisted in Redis)	High
TC-	Unauthenticated access	No token	Access token Blacklisted in Redis		

AUTH-070	Horizontal privilege escalation	User A authenticated	Access user B's profile update endpoint using user A's token	HTTP 403; unauthorized	Critical
TC-AUTH-071	Admin-only endpoint accessed with user token	Regular user authenticated	POST /auth/register-admin or admin route with user JWT	HTTP 403	Critical
TC-AUTH-072	SQL/NoSQL injection in login password field	N/A	password = { "\$ne": null }	HTTP 422 or sanitized; no auth bypass	Critical
TC-AUTH-073	Brute-force OTP attack blocked by rate limiter	N/A	Rapid repeated POST /auth/verify-email calls	HTTP 429 after emailVerificationLimiter threshold	High
TC-AUTH-074	CORS — request from disallowed origin	N/A	Request with Origin: https://evil.com	CORS headers absent or 403; cookie not sent	High
TC-AUTH-075	Cookie flags — httpOnly and Secure set on tokens	HTTPS environment	Inspect Set-Cookie on login response	Cookie has HttpOnly; Secure; SameSite=Strict flags	High